CREDPAY / REVISÃO TÉCNICA / 01

Segurança com contexto

Relatório da primeira análise SonarQube Cloud e proposta de prioridades

CredPay

05 novembro 2026 | main | Joaomagh_credpay

28	14	4	10
apontamentos	com impacto Security	Security High	Security Medium

A análise de main encontrou 28 apontamentos únicos. Desses, 14 têm impacto Security: 4 High e 10 Medium. Os outros 14 tratam de confiabilidade, manutenibilidade ou acessibilidade. Todos estavam OPEN no recorte coletado.

Os quatro High de segurança estão na pesquisa de sandbox, em comparações de configuração com /tmp. A inspeção indica provável falso positivo de contexto; nenhuma ocorrência foi encerrada. Essa pesquisa permanece incompleta e não liberada para uso.

Os dez Medium de segurança são seis downloads de ferramentas no CI sem restrição explícita de protocolos nos redirects, um fluxo de URL de download de pacotes e três credenciais fictícias usadas em Kubernetes descartável.

A análise atual não contabilizou Java na distribuição de linhas por linguagem e não tem cobertura importada. Logo, não sustenta uma conclusão sobre a segurança completa dos dois serviços Spring Boot. O quality gate aparece como Not computed.

Esta revisão não confirmou incidente, vazamento de credencial real ou exploração remota. Também não prova sua ausência. Os achados e as lacunas permanecem abertos até validação e decisão específica.

Recorte analisado

ccdd3e65e68b759e76b85ae821891485b9e61f1c

Análise 432288d7-ac7e-437a-93b2-068fafe50292 | 2026-11-05T11:22:36-03:00

Relatório técnico de triagem. Prioridades propostas; nenhum estado remoto alterado. Não é certificação nem exportação oficial do fornecedor.

Ordem de trabalho

A severidade informa impacto potencial. A prioridade considera exposição, controles existentes e esforço de validação.

P1 / Completar a análise

Conectar CI com classes Java dos dois serviços, separar fontes/testes e importar dois JaCoCo + LCOV. Conferir os avisos e a análise do mesmo SHA.

P1 / Reforçar seis downloads

S05-S10: restringir curl a HTTPS em URL e redirects, preservando versões, TLS e hashes. Testar o bloqueio de downgrade e os workflows afetados.

P1 / Reduzir custo no frontend

Q01-Q02: remover algoritmos de regex superlineares com TDD; manter dinheiro exato e recibo/idempotência. Custo local foi observado, sem DoS remoto demonstrado.

P1 externo / Segredos da publicação

S12-S14: impedir exemplos conhecidos no destino e provisionar credenciais exclusivas fora do Git. No ensaio descartável atual, a revisão contextual é P3.

P2 / Revisar a sandbox e o produto

S01-S04/S11: triagem por ID e testes negativos, sem liberar pesquisa. Q03/Q04/Q07: semântica da moeda, prova de cancelamento e nome de variável PowerShell.

P3 / Isolar fixtures e referências

Q05/Q06/Q08-Q14: escopo dos stubs, parser ELF e mockups históricos. Preservar originais e o inventário. Não editar referências para maquiar métricas.

Condições de fechamento

Uma correção precisa de teste quando houver comportamento, check afetado verde e nova análise do mesmo SHA. Falso positivo exige justificativa por ocorrência. Credenciais públicas de ensaio não entram no destino externo. Referências históricas continuam preservadas.

P1: próximo incremento ou condição antes da publicação. P2: revisão/correção subsequente. P3: manutenção ou pesquisa sem exposição demonstrada no produto. Nenhum P0 foi confirmado nesta inspeção.

Os quatro High de segurança

Todos pertencem à regra python:S5443, na pesquisa de sandbox. A classificação do fornecedor foi preservada.

S01 Diretório temporário: conjunto permitido do worker

infra/agent-sandbox/containment.py:138 | python:S5443 | Security High | P2

Avaliação. Provável falso positivo de contexto; revisão formal pendente.

A regra S5443 procura uso inseguro de diretórios graváveis por outros usuários. Nesta ocorrência, a expressão compara as chaves de HostConfig.Tmpfs com o conjunto permitido contendo /tmp. Não cria nem abre um arquivo temporário.

Contexto. containment.py:138 verifica o destino e exige exatamente rw,noexec,nosuid,nodev,size=256m. O worker exige UID/GID10001, rootfs somente leitura, capabilities removidas e rede none neste perfil. Isso não comprova contenção completa nem libera a sandbox experimental.

Próximo passo. Revisar esta ocorrência com os controles negativos e registrar a justificativa individual no SonarQube. Preservar as verificações; evitar renomear constantes apenas para esconder o alerta.

Aceite. Revisão reproduzível da expressão e dos mounts; rejeição de destino/opções divergentes; decisão explícita por ID antes de encerrar o achado.

Abrir ocorrência AaGsF8vpDE2kr22yY43g

S02 Diretório temporário: chave de consulta das opções

infra/agent-sandbox/containment.py:138 | python:S5443 | Security High | P2

Avaliação. Provável falso positivo de contexto; revisão formal pendente.

Segundo apontamento na mesma linha 138. O literal /tmp é a chave usada para consultar as opções do tmpfs inspecionado; não é um segundo arquivo vulnerável.

Contexto. A comparação recusa opções diferentes da allowlist. A duplicidade de linha corresponde a duas posições distintas marcadas pelo analisador e foi preservada no inventário.

Próximo passo. Revisar separadamente o acesso ao dicionário e a allowlist, mantendo a rastreabilidade entre S01 e S02.

Aceite. Confirmar que nenhuma operação de arquivo ocorre nesse ponto e manter teste que recuse opções extras ou ausentes. Sem supressão geral da regra.

Abrir ocorrência AaGsF8vpDE2kr22yY43h

High: continuação da revisão

Os pontos marcados são comparações de configuração; a segurança completa do ambiente continua fora desta conclusão.

S03 Diretório temporário: identificação do mount inspecionado

infra/agent-sandbox/containment.py:142 | python:S5443 | Security High | P2

Avaliação. Provável falso positivo de contexto; revisão formal pendente.

Na linha 142, o código identifica um mount cujo tipo é tmpfs e destino é /tmp. O literal serve à inspeção da configuração, sem criação de arquivo.

Contexto. A verificação anterior exige um único destino tmpfs e suas opções. Os outros mounts passam pela validação de origem, destino, propagação e propriedade do bind da fixture.

Próximo passo. Conferir a sequência completa dos guards e seus casos negativos antes de propor o encerramento por falso positivo.

Aceite. Mount extra, bind inesperado e opções divergentes continuam recusados; justificativa vinculada ao ID S03.

Abrir ocorrência AaGsF8vpDE2kr22yY43i

S04 Diretório temporário: validação do container de origem

infra/agent-sandbox/source_ci.py:32 | python:S5443 | Security High | P2

Avaliação. Provável falso positivo de contexto; revisão formal pendente.

source_ci.py:32 compara o tipo e o destino dos mounts observados. A operação sinalizada não cria arquivo em diretório público.

Contexto. O controlador recusa mounts que não sejam tmpfs em /tmp, confere imagem/ID/label e exige que o container de inventário nunca tenha sido iniciado. Esse guard isolado não constitui prova completa de segurança da sandbox.

Próximo passo. Revisar o uso como comparação e a cadeia de identidade/estado. Não promover a pesquisa de sandbox como resultado desta triagem.

Aceite. Testes de imagem/ID e mount indevido preservados; decisão de triagem específica. Nenhum aceite automático de vulnerabilidade.

Abrir ocorrência AaGsF8vnDE2kr22yY43f

Seis Medium nos downloads do CI

S6506: declarar HTTPS também para os redirecionamentos. URLs oficiais e hashes já existentes reduzem o risco, mas não substituem a política explícita de transporte.

S05 Download de Node no Compose CI permite redirecionamento sem restrição explícita

.github/workflows/credpay-compose-ci.yml:139 | githubactions:S6506 | Security Medium | P1

Avaliação. Melhoria concreta de defesa do CI; exploração não demonstrada.

Contexto. credpay-compose-ci.yml:139 baixa Node24.22.1 de nodejs.org e confere SHA256 fixo antes da extração. O hash reduz o risco de aceitar conteúdo alterado, mas a restrição de transporte ainda pode ser explícita.

Próximo passo. Adicionar --proto '=https' e --proto-redir '=https', preservando validação TLS, SHA256 e falha antes da extração.

Abrir ocorrência AaGsF8v3DE2kr22yY43q

S06 Download de Node no Frontend CI sem restrição explícita de redirects

.github/workflows/frontend-ci.yml:45 | githubactions:S6506 | Security Medium | P1

Avaliação. Melhoria concreta de defesa do CI; exploração não demonstrada.

Contexto. frontend-ci.yml:45 usa Node24.22.1 oficial com SHA256 fixo e só extrai após a conferência. Não há indicação de download malicioso observado.

Próximo passo. Restringir curl a HTTPS na requisição e nos redirects; manter versão, hash, isolamento de configurações npm e validação TLS.

Abrir ocorrência AaGsF8v0DE2kr22yY43n

S07 Download de kind no Kubernetes CI sem restrição explícita de redirects

.github/workflows/credpay-kubernetes-ci.yml:97 | githubactions:S6506 | Security Medium | P1

Avaliação. Melhoria concreta de defesa do CI; exploração não demonstrada.

Contexto. credpay-kubernetes-ci.yml:97 verifica SHA256 antes de chmod/execução. A exceção de node privilegiado continua restrita ao runner descartável autorizado.

Próximo passo. Exigir HTTPS para URL e redirects, sem mudar checksum, baseline, privilégios ou escopo do cluster.

Abrir ocorrência AaGsF8v1DE2kr22yY43o

Downloads: continuação

A correção proposta preserva versões e checksums. Não desabilitar TLS nem enfraquecer o canário de segredos para obter um resultado verde.

S08 Download de kubectl no Kubernetes CI sem restrição explícita de redirects

.github/workflows/credpay-kubernetes-ci.yml:99 | githubactions:S6506 | Security Medium | P1

Avaliação. Melhoria concreta de defesa do CI; exploração não demonstrada.

Contexto. Linha 99 fixa kubectl1.36.4, com SHA256 na linha seguinte. A configuração usa kubeconfig próprio em vez do contexto pessoal de João.

Próximo passo. Restringir requisição/redirects a HTTPS, mantendo checksum e kubeconfig isolado.

Abrir ocorrência AaGsF8v1DE2kr22yY43p

S09 Download de Gitleaks no Secret Scan sem restrição explícita de redirects

.github/workflows/secret-scan.yml:36 | githubactions:S6506 | Security Medium | P1

Avaliação. Melhoria concreta de defesa do CI; exploração não demonstrada.

Contexto. secret-scan.yml:36 usa release oficial fixa e SHA256; o canário exige código42 e o scanner usa redação. Não foi identificado vazamento por este achado.

Próximo passo. Adicionar restrição HTTPS sem alterar canário, versões, hashes, regras ou exceções do scanner.

Abrir ocorrência AaGsF8v4DE2kr22yY43r

S10 Download de Trivy no inventário sem restrição explícita de redirects

.github/workflows/vulnerability-inventory.yml:90 | githubactions:S6506 | Security Medium | P1

Avaliação. Melhoria concreta de defesa do CI; exploração não demonstrada.

Contexto. vulnerability-inventory.yml:90 fixa Trivy0.75.0 e confere SHA256 antes da extração. Os achados de dependências registrados no inventário são um conjunto separado dos achados SAST deste relatório.

Próximo passo. Exigir HTTPS na URL e em redirects, conservando os quatro alvos, metadados e política de inventário.

Abrir ocorrência AaGsF8vyDE2kr22yY43m

Aceite comum S05-S10: --proto '=https' e --proto-redir '=https', download oficial validado, downgrade HTTP recusado e workflow afetado concluído. Nenhuma exploração foi reproduzida.

Medium no fluxo de pacotes

S11: dados de um lockfile local chegam a uma chamada de rede no controlador da pesquisa.

S11 Traversal na URL de download dos pacotes da pesquisa de sandbox

infra/agent-sandbox/core_ci.py:88 | pythonsecurity:S7044 | Security Medium | P2

Avaliação. Fluxo sinalizado com validações relevantes existentes; hipótese de exploração pendente.

S7044 rastreia um caminho lido do JSON de pacotes até urlopen(origin + path). Se esse valor contornar as validações, pode alterar o recurso requisitado. O fluxo da ferramenta rotula a origem genericamente como HTTP, mas no código ela vem de um lockfile local versionado.

Contexto. package_baseline chama validate_packages antes do download: nomes esperados, arquitetura amd64, path pool/main, caracteres permitidos, recusa de segmentos '..', extensão .deb, tamanho limitado e SHA256. A origem é uma constante Debian/Ubuntu. O teste existente rejeita pool/main/../../outside_amd64.deb. Redirects finais de urlopen ainda merecem análise própria.

Próximo passo. Ampliar testes para caminho absoluto, host, percent-encoding, query, fragmento e redirecionamento; explicitar URL normalizada e política de destino se necessário. Preservar hash/tamanho e isolamento da pesquisa.

Aceite. Casos maliciosos recusados antes da requisição; origem/caminho e redirects caracterizados. Decisão fundamentada no SonarQube, sem liberar o core experimental.

Abrir ocorrência AaGsF8vlDE2kr22yY43e

Controles observados

A validação já rejeita segmentos de traversal, caracteres fora da lista, tamanhos inválidos e hashes malformados. Os testes existentes cobrem um caminho com ../.., mas ainda falta caracterizar a política de redirects e os demais casos adversariais.

A decisão de adiar a sandbox continua válida. Revisar este fluxo não significa liberar o core, aceitar os achados de dependências ou ampliar privilégios do agente.

Três Medium em senhas de exemplo

O manifesto é aplicado no ensaio Kubernetes descartável. Todos os valores são públicos e fictícios; não podem ser reutilizados num destino externo.

S12 Senha fictícia do banco de transações no manifesto de exemplo

infra/k8s/secret.example.yaml:9 | yaml:S2068 | Security Medium | P1 antes da publicação

Avaliação. Credencial pública deliberada de ensaio; proibida para ambiente externo.

Contexto. verify-startup.ps1 aplica esse exemplo no cluster descartável. Portanto, o valor é usado em ensaio; não deve ser descrito como mera documentação sem execução. Nenhuma credencial real foi identificada nesta inspeção.

Próximo passo. Manter o escopo descartável explícito e impedir uso desse manifesto na publicação. Provisionar senha exclusiva por destino fora do Git, com permissões mínimas e validação que recuse exemplos conhecidos.

Abrir ocorrência AaGsF8vtDE2kr22yY43j

S13 Senha fictícia do banco de processamento no manifesto de exemplo

infra/k8s/secret.example.yaml:11 | yaml:S2068 | Security Medium | P1 antes da publicação

Avaliação. Credencial pública deliberada de ensaio; proibida para ambiente externo.

Contexto. O manifesto é aplicado apenas pelo roteiro de teste conferido; os valores são públicos e conhecidos. Não há prova de vazamento de uma senha privada neste achado.

Próximo passo. Provisionar uma credencial exclusiva do processamento no destino externo e impedir reutilização do exemplo ou compartilhamento indevido entre bancos.

Abrir ocorrência AaGsF8vtDE2kr22yY43k

S14 Senha fictícia do RabbitMQ no manifesto de exemplo

infra/k8s/secret.example.yaml:13 | yaml:S2068 | Security Medium | P1 antes da publicação

Avaliação. Credencial pública deliberada de ensaio; proibida para ambiente externo.

Contexto. Uso presente no ensaio Kubernetes descartável. Banco, AMQP e management precisam continuar internos na futura demo pública. Nenhum acesso externo com esse exemplo foi comprovado.

Próximo passo. Gerar credencial exclusiva no destino, definir permissões do broker e manter portas administrativas/AMQP internas. Bloquear uso do manifesto de ensaio no deployment público.

Abrir ocorrência AaGsF8vtDE2kr22yY43l

Frontend: custo e acessibilidade

Estes itens têm impacto de confiabilidade ou manutenibilidade. Mantêm relevância para a experiência e para a preparação da publicação.

Q01 Regex de zeros finais no diário da criação

frontend/src/app/creation-journal.ts:21 | typescript:S8786 | Reliability Medium | P1

Avaliação. Custo superlinear observado em experimento isolado.

creation-journal.ts:21 usa /0+$/ sem âncora inicial para remover zeros finais. Uma sequência longa de zeros seguida de outro dígito força tentativas em várias posições.

Contexto. Node24.22.1/Windows, uma medição por tamanho: 4096 zeros 11,94ms; 8192 41,58ms; 16384 164,62ms. O registro carregado é limitado a65536 caracteres. Experimento da expressão, sem ataque integrado ao navegador ou backend.

Próximo passo. Substituir por varredura linear mantendo identidade decimal/expoente com BigInt, recibo original e rejeição de registro inválido. Escrever o teste red antes de alterar comportamento.

Aceite. Casos adversariais e decimais equivalentes passam sem arredondamento; suíte Angular, build e nova análise preservados. Evitar teste dependente de milissegundos exatos.

Abrir ocorrência AaGsF8vODE2kr22yY43Y

Q02 Regex de agrupamento monetário na apresentação

frontend/src/app/transaction.ts:24 | typescript:S8786 | Reliability Medium | P1

Avaliação. Custo superlinear observado em experimento isolado.

transaction.ts:24 usa lookahead repetido para inserir separadores de milhar. Para cada posição, a regex pode percorrer novamente boa parte do número.

Contexto. Na mesma medição: 4096 dígitos 12,59ms; 8192 51,71ms; 16384 260,29ms. O custo ocorre no cliente. Isso não demonstra DoS remoto do servidor; os limites atuais do contrato também precisam entrar na avaliação integrada.

Próximo passo. Agrupar a string em blocos em tempo linear, preservando centavos, zeros, expoentes e valores além do inteiro seguro sem converter dinheiro para Number.

Aceite. Testes red/green de entradas grandes, exatas e inválidas; renderização responsiva, 45 cenários atuais e nova análise sem regressão.

Abrir ocorrência AaGsF8vODE2kr22yY43Z

Frontend: semântica e prova de teste

Q03 Label da moeda sem controle associado

frontend/src/app/create-page.html:9 | Web:S6853 | Reliability Medium | P2

Avaliação. Problema de semântica/acessibilidade no frontend entregue.

create-page.html:9 apresenta moeda fixa com um label, mas não existe campo editável ao qual associá-lo. Pode confundir a interpretação por tecnologia assistiva.

Contexto. A moeda é exibida em um div com BRL/Real brasileiro. O input de valor já tem label com for=amount; o alerta é sobre a moeda fixa.

Próximo passo. Usar texto de legenda apropriado para informação estática, ou output/grupo com nome acessível se necessário; não criar controle fictício só para satisfazer a regra.

Aceite. Nome da moeda acessível, navegação por teclado preservada e teste semântico antes da mudança; conferir desktop/mobile com a skill de QA.

Abrir ocorrência AaGsF8vMDE2kr22yY43X

Q04 Teste de cancelamento sem expect reconhecido pelo analisador

frontend/src/app/transactions-api.spec.ts:43 | typescript:S2699 | Maintainability Blocker | P2

Avaliação. Asserção de fronteira já existe; possível limitação de reconhecimento.

transactions-api.spec.ts:43 testa a saída da tela e usa HttpTestingController.expectNone após cancelar a assinatura. O Sonar não reconheceu essa chamada como asserção e classificou o impacto de manutenibilidade como Blocker.

Contexto. expectOne/expectNone da API de teste Angular falham se a quantidade de requisições divergir. O cenário não é um teste vazio. A classificação Blocker é de manutenibilidade, sem impacto de segurança associado na resposta coletada.

Próximo passo. Caracterizar emissão/cancelamento com uma asserção de estado observável, sem substituir a verificação de ausência de HTTP. Se mantida a implementação, justificar a limitação por ID.

Aceite. Teste falha quando há consulta após unsubscribe ou emissão indevida; continua comprovando ausência de novo HTTP. Nenhuma asserção tautológica.

Abrir ocorrência AaGsF8tsDE2kr22yY43W

A suíte Angular possui 45 cenários verdes no incremento de cobertura anterior. Este relatório não reexecutou o navegador nem declarou uma nova jornada manual integrada; os testes de produto devem ser repetidos quando as correções entrarem.

Diagnóstico e pesquisa

Q05-Q08: distinguir controles intencionais de testes, conflito de nome e custo de parsing.

Q05 Fixture sombreia Invoke-WebRequest

infra/compose/check-diagnostic-http.ps1:27 | powershelldre:S8625 | Reliability Medium · Maintainability Medium | P3

Avaliação. Sombreamento intencional em controle de teste; avaliar isolamento.

Contexto. É um script de verificação, com docker também interceptado, não o adapter de produção. Renomear apenas a função faria perder a proteção do fallback nativo.

Próximo passo. Conferir escopo e restauração; preferir isolamento explícito/injeção da fronteira somente se isso mantiver o controle negativo. Justificar o teste se a regra não distingue fixtures.

Abrir ocorrência AaGsF8vcDE2kr22yY43c

Q06 Fixture sombreia Start-Sleep

infra/compose/check-diagnostic-fault.ps1:45 | powershelldre:S8625 | Reliability Medium · Maintainability Medium | P3

Avaliação. Sombreamento intencional em teste de falhas; avaliar isolamento.

Contexto. O objetivo é controlar tempo na fixture. Remover o stub sem estudar o desenho pode reintroduzir atrasos reais nos controles.

Próximo passo. Isolar o stub no escopo do teste e verificar que não afeta a execução posterior; refatorar a fronteira de tempo só se houver ganho concreto.

Abrir ocorrência AaGsF8vaDE2kr22yY43b

Q07 Variável $event conflita com nome automático do PowerShell

infra/compose/diagnostic-evidence.ps1:94 | powershelldre:S8626 | Reliability Medium | P2

Avaliação. Correção pequena recomendada para confiabilidade do diagnóstico.

Contexto. O roteiro já passou no contexto ensaiado, mas o nome pode depender do escopo/contexto de execução. O alerta não relata acesso indevido a transações.

Próximo passo. Renomear para $creationEventId em todos os usos dessa função e verificar o diagnóstico afetado, sem mudar SQL, identidade ou prova causal.

Abrir ocorrência AaGsF8vXDE2kr22yY43a

Q08 Regex de identificação ELF na pesquisa de sandbox

infra/agent-sandbox/project_core.py:65 | python:S8786 | Reliability Medium | P3

Avaliação. Custo/limites de entrada ainda precisam de caracterização.

Contexto. Esse parser opera no controlador da pesquisa de sandbox, fora da API pública. O experimento de regex do frontend não foi aplicado aqui e não serve como prova para este item.

Próximo passo. Medir entradas adversariais de saída de ferramenta e preferir parse por linha/limites explícitos, mantendo rejeição de arquitetura, loader e RPATH divergentes.

Abrir ocorrência AaGsF8vfDE2kr22yY43d

As seis referências de design

Os HTMLs Stitch foram preservados para consulta. Não entram no bundle Angular atual. O inventário continua exibindo cada ocorrência histórica.

Q09 Referência Stitch principal sem título HTML

docs/frontend/references/code.html:3 | Web:PageWithoutTitleCheck | P3

docs/frontend/references/code.html:3 não contém title. Se servido como página, perde identificação acessível da aba.

Tratamento. Preservar o original. Se o arquivo for transformado em página publicada, corrigir na implementação derivada. Documentar eventual escopo do scanner sem apagar o achado histórico.

Q10 Referência Stitch export-02 sem título HTML

docs/frontend/references/export-02/code.html:3 | Web:PageWithoutTitleCheck | P3

A página export-02/code.html:3 também não possui title. É uma ocorrência separada do arquivo principal.

Tratamento. Preservar original e aplicar requisito de título somente a uma derivação executável/publicada.

Q11 Label sem associação na referência export-02

docs/frontend/references/export-02/code.html:32 | Web:S6853 | P3

export-02/code.html:32 tem label sem controle/nome acessível válido, mesma família de regra Web:S6853.

Tratamento. Manter rastreabilidade de design e verificar semântica na implementação real.

Q12 Elemento interativo sem semântica nativa na referência export-02

docs/frontend/references/export-02/code.html:177 | Web:S6848 | P3

export-02/code.html:177 usa interação num elemento sem semântica/teclado adequados. Controles nativos normalmente oferecem essas propriedades por padrão.

Tratamento. Nas telas implementadas, usar button/link de acordo com a ação e validar teclado; não editar o arquivo histórico só para baixar contagem.

Q13 Truncamento por operação bit a bit na referência export-02

docs/frontend/references/export-02/code.html:268 | javascript:S7767 | P3

export-02/code.html:268 usa |0. Essa operação converte para inteiro de32 bits e pode mudar números grandes; Math.trunc comunica truncamento sem essa conversão.

Tratamento. Preservar o original e proibir reutilização desse cálculo no fluxo monetário. Corrigir somente uma derivação executável, se criada.

Q14 Truncamento por operação bit a bit na referência export-03

docs/frontend/references/export-03/code.html:346 | javascript:S7767 | P3

export-03/code.html:346 contém o mesmo padrão |0, com risco de conversão para inteiro de32 bits.

Tratamento. Conservar o arquivo de origem e garantir que a implementação real continue usando cálculo decimal exato.

Rastreabilidade dos 28 itens

Cada referência deste relatório aponta para uma ocorrência única. O catálogo Markdown acompanha os links individuais e os critérios de aceite completos.

Ref.	Regra / qualidade e impacto	Prioridade	Estado
S01	python:S5443 / Segurança HIGH	P2	OPEN
S02	python:S5443 / Segurança HIGH	P2	OPEN
S03	python:S5443 / Segurança HIGH	P2	OPEN
S04	python:S5443 / Segurança HIGH	P2	OPEN
S05	githubactions:S6506 / Segurança MEDIUM	P1	OPEN
S06	githubactions:S6506 / Segurança MEDIUM	P1	OPEN
S07	githubactions:S6506 / Segurança MEDIUM	P1	OPEN
S08	githubactions:S6506 / Segurança MEDIUM	P1	OPEN
S09	githubactions:S6506 / Segurança MEDIUM	P1	OPEN
S10	githubactions:S6506 / Segurança MEDIUM	P1	OPEN
S11	pythonsecurity:S7044 / Segurança MEDIUM	P2	OPEN
S12	yaml:S2068 / Segurança MEDIUM	P1 externo	OPEN
S13	yaml:S2068 / Segurança MEDIUM	P1 externo	OPEN
S14	yaml:S2068 / Segurança MEDIUM	P1 externo	OPEN
Q01	typescript:S8786 / Confiab. MEDIUM	P1	OPEN
Q02	typescript:S8786 / Confiab. MEDIUM	P1	OPEN
Q03	Web:S6853 / Confiab. MEDIUM	P2	OPEN
Q04	typescript:S2699 / Manut. BLOCKER	P2	OPEN
Q05	powershelldre:S8625 / Confiab. MEDIUM, Manut. MEDIUM	P3	OPEN
Q06	powershelldre:S8625 / Confiab. MEDIUM, Manut. MEDIUM	P3	OPEN
Q07	powershelldre:S8626 / Confiab. MEDIUM	P2	OPEN
Q08	python:S8786 / Confiab. MEDIUM	P3	OPEN
Q09	Web:PageWithoutTitleCheck / Confiab. MEDIUM	P3	OPEN
Q10	Web:PageWithoutTitleCheck / Confiab. MEDIUM	P3	OPEN
Q11	Web:S6853 / Confiab. MEDIUM	P3	OPEN
Q12	Web:S6848 / Confiab. MEDIUM, Manut. LOW	P3	OPEN
Q13	javascript:S7767 / Manut. HIGH, Confiab. HIGH	P3	OPEN
Q14	javascript:S7767 / Manut. HIGH, Confiab. HIGH	P3	OPEN

A severidade histórica da API usa CRITICAL para os quatro Security HIGH e BLOCKER para Q04. São classificações do mesmo item, não achados adicionais. Dois itens High de confiabilidade/manutenibilidade estão nas referências Q13/Q14.

Método, evidências e limites

Coleta. Consultas públicas às APIs de issues, análises, medidas, hotspots e regras. 28 issues OPEN, 0 hotspots. Dados coletados em05/11/2026; SHA e análise identificados na capa. Sem senha/token utilizado nesta coleta.

Inspeção. Leitura dos arquivos locais no SHA analisado. Achados agrupados por causa, com identidade individual preservada. Nenhum status, regra, exclusão, severidade ou quality gate foi alterado.

Teste existente. Python unittest da pesquisa: 71 descobertos, 70 passaram e 1 ignorado por plataforma Windows. Não executou Docker, controles reais de contenção nem validação externa.

Experimento. Node24.22.1/Windows, expressões isoladas, uma amostra por tamanho. Resultados nas fichas Q01/Q02. Não mede ataque integrado, desempenho de produção ou significância estatística.

Lacunas da análise. Sem Java na distribuição de linhas e sem cobertura importada. Dois avisos observados: Python assumido3.10-3.14 e testes Python sem sonar.tests. A causa da omissão de Java ainda exige diagnóstico.

Limites da conclusão. Não é pentest, auditoria de infraestrutura nem certificação. Os achados Trivy/GnuTLS e o aceite pessoal de release são trilhas separadas. Não houve deploy, correção de código, aceite de risco ou promessa de produto100%.

Fontes primárias

1. Projeto e lista de issues
2. Issues públicas, consulta de 28 itens
3. Análise e revisão do código
4. Distribuição de linguagens
5. Limites da análise automática
6. curl: protocolos nos redirecionamentos
7. Revisão de código no SHA analisado

Os links S01-S14 e Q01-Q14 são clicáveis nas fichas e no índice. A versão textual completa está em docs/SONARQUBE_REVIEW.md no repositório.